

1/28

□

File No.: EXP202209203

RESOLUTION OF TERMINATION OF THE PROCEDURE BY VOLUNTARY PAYMENT

From the procedure initiated by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: On October 3, 2023, the Director of the Spanish Agency for Data Protection decided to initiate sanctioning proceedings against MAPFRE ESPAÑA COMPAÑÍA DE SEGUROS Y REASEGUROS, S.A. (hereinafter, the claimed party), through the Agreement that is transcribed:

<<

File No.: EXP202209203

AGREEMENT TO INITIATE SANCTIONING PROCEDURE

From the actions taken by the Spanish Agency for Data Protection and based on the following

FACTS

FIRST: On July 4, 2022, A.A.A. on behalf of B.B.B. (hereinafter, the claiming party) filed a complaint with the Spanish Agency for Data Protection.

The complaint is directed against MAPFRE ESPAÑA COMPAÑÍA DE SEGUROS Y REASEGUROS, S.A. with NIF A28141935 (hereinafter, MAPFRE or the claimed party).

The reasons on which the complaint is based are as follows:

The claiming party is a guarantor in a rental contract signed by her daughter.

The owners of the property (to protect themselves against possible defaults) take out a rental insurance policy (with the claimed party), under which the claimed party requests the claiming party to provide her last three payslips and a document certifying the indefinite nature of the employment contract, documentation that is provided.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

2/28

However, after the delivery of this documentation, the claimed party also requests a copy of the claiming party's income tax declaration (IRPF) as well as her employment history.

As a result of this request, the claiming party asks (on June 17, 2022) to know the purpose of the processing of the requested data, as well as the recipients of her data and any possible transfers of the same, receiving a response from the claimed party (on June 17, 2022) indicating, on the one hand, that the claiming party is not a client of the entity and, on the other hand, that the information is requested by the owner of the property.

Consequently, the claiming party filed a complaint with this Agency, considering that the claimed party requests the claiming party (guarantor) for her personal data without guaranteeing their protection, alleging that the data is requested by the property owner.

Along with the complaint, an exchange of emails with the claimed party related to the documentation requests, the request for information regarding the processing of the data, and a copy of the response received to the access request is provided, in which the following is indicated:

"The guarantor is not our client, and the documentation sent to us is archived in the system, and if the policy is issued, we attach it in a special file for review by SSCC since there are protection operations that audit us. Thank you. Regards."

Additionally, a copy of an information sheet provided at another office of the claimed party is included, where the documents to be provided for default insurance are listed.

SECOND: In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on Personal Data Protection and the guarantee of digital rights (hereinafter LOPDGDD), on September 7, 2022, this complaint was forwarded to the claimed party, so that it could analyze it and inform this Agency within one month of the actions taken to comply with the requirements set forth in the data protection

regulations.

Once the complaint was forwarded to the claimed party, on October 7, 2022, a letter was received in this Agency from this party stating that since the claiming party requests information regarding the processing of her personal data, a new communication has been sent to her informing her about the circumstances related to the processing of her data, as well as how this information has already been incorporated into the documentation of the policy provided to the policyholder, who is ultimately the one who has contacted and requested the guarantor to provide the necessary documentation to formalize the Rental Protection Insurance policy.

The claimed party adds that in the context of subscribing to rental protection insurance policies, and as established in the entity's ISSUANCE and UNDERWRITING RULES document, it is the policyholder or landlord who interacts with the entity from the moment of the insurance request and is

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/28

who, from the questionnaire for the conclusion of the contract, declares to my represented party all the circumstances and information necessary for the assessment of the risk, among which is the verification of the tenant's payment capacity and the storage of the documentation that proves such capacity, including, where applicable, that of the guarantor.

Consequently, the obligation and commitment to verify the sufficient payment capacity of the tenant and to provide the entity with all the economic documentation of the tenant or their guarantor that proves it at the time of formalizing the contract, corresponds to the landlord who is the policyholder.

It is therefore concluded that the documents indicated in the claim for the risk assessment (payroll, contract, etc.) are collected by the policyholder, who, by adhering to the application or contract, has acknowledged and guaranteed to the entity "having collected and having the prior consent of the same for the communication of their data and having informed them, prior to their inclusion in this document, of the purposes of the processing, communications, and other terms provided therein and in the Additional Information on Data Protection."

However, according to statements from the responding party, upon receiving the transfer of the claim, they interpreted that the landlord had not properly informed the claiming party about the processing of their personal data and sent a communication on October 7, 2022, by email to the claiming party informing them of what is established in Article 14 of Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, regarding the protection of natural persons with regard to the processing of personal data and the free movement of such data (hereinafter, GDPR).

They attach the following relevant documentation:

- Rules for issuance, underwriting, and rates for rental protection 2022.
- Particular Conditions of Rental Protection Insurance
- Application and Questionnaire for Rental Protection Insurance
- Copy of the email dated October 7, 2022, sent by the responding party to the claiming party informing them of the processing of their personal data.

THIRD: On October 4, 2022, in accordance with Article 65 of the LOPDGDD, the claim submitted by the claiming party was admitted for processing.

FOURTH: The General Sub-Directorate for Data Inspection proceeded to carry out preliminary investigative actions to clarify the facts in question, by virtue of the functions assigned to the control authorities in Article 57.1 and the powers granted in Article 58.1 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and in accordance with the provisions of Title VII, Chapter I, Section Two, of the LOPDGDD, having knowledge of the following points:

Regarding the data collected.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

It is verified that in the document "IT. ATNV. PP. EMISSION, SUBSCRIPTION AND RENTAL PROTECTION RATES 2022 - Rental Protection Insurance Product - BRANCH 027" (page 10) it is established in heading 2.2 letter A that the options for required documentation for an employed individual or civil servant are, alternatively:

- The latest payslip showing seniority and type of contract (if not expressly detailed, a certificate from the company must be attached to certify this, a copy of the employment contract, or work history) and the latest income tax return. However, without any conditions, the following alternatives are offered:
- Bank guarantee for a minimum amount of three months' rent.
- Personal guarantee from a guarantor with sufficient payment capacity evidenced by the documentation indicated in the first point of this list.

In the case at hand, and according to the present claim, the first option was chosen.

Requested from the DPD of the responding party a report on the product "Rental Insurance," on November 30, 2022, the requested report was received in this Agency, stating that "the documents indicated to demonstrate the tenant's solvency are alternative and their selection is made in accordance with the quality of the tenant, which is exclusively known by the policyholder because it is he who holds the tenant's documents; therefore, the commercial agent performs a guiding function of information regarding the documentary options stipulated by the entity."

Upon examining the documentation in the file, it is verified that among the contracting conditions, the obligation to collect these documents falls on the landlord/policyholder of the insurance.

In this regard, it is noted in the document "Application and Questionnaire for Rental Protection Insurance" (Templates and Forms Financial Losses 5-2019, page 2) the paragraph "The applicant in his capacity as landlord of the described dwelling declares that he has received and holds in his possession some of the following documents provided by the tenant(s) or guarantor(s) in the case of a personal guarantee, for the purpose of justifying the payment capacity of the tenant(s) [...]" and in the observations section of the Particular Conditions of the Insurance, page 2 signed by the policyholder "The policyholder in his capacity as landlord of the described dwelling declares that: he has received and holds in his possession some of the following documents provided by the tenants or guarantors in the case of a personal guarantee, [...]."

Regarding the duty to inform

In the report issued by the DPD of the responding entity regarding the product "Rental Insurance," it is stated that "The tenant is a third party, with whom MAPFRE ESPAÑA has no legal relationship. Therefore, it is the owner/landlord who wishes to contract the protection of his rental, who requests from his future tenant the data, and informs him of the purpose for which they will be processed." Furthermore, in this report, the DPD states that the obligation to inform the tenant falls on the landlord/policyholder of the insurance.

According to these statements, it is verified in the documents Application and Questionnaire for Rental Protection Insurance (document Templates and Forms, page 3) and Particular Conditions of the Insurance, page 5 (the latter signed by

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

the policyholder, the existence of the paragraph "in the event that the personal data provided refers to third parties, the policyholder acknowledges and guarantees having obtained and having the prior consent of the same for the communication of their data and having informed them, prior to their inclusion in this document, of the purposes of the processing, communications, and other terms provided therein and in the Additional Information on Data Protection."

Requested from the landlord a document informing the claimant about the processing of their personal data, on May 31, 2023, a response letter was received in this Agency stating that no document exists that can verify that the claimant was correctly informed about the processing of their personal data because this information was provided verbally.

The responding party provided, among other documents, the following:

- Copy of the lease contract dated June 11, 2022
- Compliance evaluation report for rental protection insurance
- Specific conditions of the rental protection insurance dated June 29, 2021, signed by Mapfre and the policyholder
- Document titled "IT.ATNV.PP.ISSUANCE, UNDERWRITING, AND RATES FOR RENTAL PROTECTION 2022"
- Template for the application and questionnaire for rental protection insurance

LEGAL GROUNDS

I

In accordance with the provisions of Articles 58.2 and 60 of Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, regarding the protection of natural persons with regard to the processing of personal data and the free movement of such data (GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 and 68.2 of Organic Law 3/2018, of December 5, on Personal Data Protection and the guarantee of digital rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Agency for Data Protection will be governed by the provisions of Regulation (EU) 2016/679, this organic law, the regulatory provisions issued in its development, and, in so far as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Preliminary Issues

Article 4 "Definitions" of the GDPR defines the following terms for the purposes of the Regulation:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

6/28

"1) 'personal data': any information relating to an identified or identifiable natural person ('the data subject'); an identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier, such as a name, an identification number, location data, an online identifier, or one or more factors specific to the physical, physiological, genetic, mental, economic, cultural, or social identity of that natural person;"

"2) 'processing': any operation or set of operations performed on personal data or sets of personal data, whether by automated means or not, such as collection, recording, organization, structuring, storage, adaptation or alteration, retrieval, consultation, use, communication by transmission, dissemination, or any other form of enabling access, alignment, combination, restriction, erasure, or destruction;"

In this case, pursuant to Article 4.1 of the GDPR, there is processing of personal data, both of the policyholder and of third parties (in this case, the guarantor) who must provide information that includes personal data, for the conclusion of the insurance contract.

MAPFRE carries out this activity in its capacity as the data controller, as it determines the purposes and means of such activity, by virtue of Article 4.7 of the GDPR.

It does not affect, as will be seen later, that MAPFRE, in relation to its information obligations, establishes in its general contracting conditions that it is the policyholder who is obliged to "have obtained and have the prior consent of the same for the communication of their data and have informed them, prior to their inclusion in this document, of the purposes of the processing, communications, and other terms provided therein and in the Additional Information on Data Protection."

III

Article 5.1.c) of the GDPR

Article 5 of the GDPR establishes that “personal data shall be:

“a) processed lawfully, fairly, and in a transparent manner in relation to the data subject (‘lawfulness, fairness, and transparency’);

b) collected for specified, legitimate purposes and not further processed in a manner that is incompatible with those purposes; according to Article 89, paragraph 1, further processing of personal data for archiving purposes in the public interest, scientific or historical research purposes, or statistical purposes shall not be considered incompatible with the initial purposes (‘purpose limitation’);

c) adequate, relevant, and limited to what is necessary in relation to the purposes for which they are processed (‘data minimization’);

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

7/28

d) accurate and, if necessary, updated; all reasonable measures will be taken to ensure that inaccurate personal data is erased or rectified without delay with respect to the purposes for which it is processed (‘accuracy’);

e) maintained in a manner that allows for the identification of the data subjects for no longer than is necessary for the purposes of processing personal data; personal data may be kept for longer periods as long as it is processed solely for archiving purposes in the public interest, scientific or historical research purposes, or statistical purposes, in accordance with Article 89, paragraph 1, without prejudice to the application of appropriate technical and organizational measures imposed by this Regulation to protect the rights and freedoms of the data subject (‘storage limitation’);

f) processed in such a way as to ensure an adequate level of security for personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, through the application of appropriate technical or organizational measures (‘integrity and confidentiality’).

The data controller shall be responsible for compliance with the provisions of paragraph 1 and be able to demonstrate it (‘proactive accountability’).”

In relation to the principle set out in letter c) above (‘data minimization’) of the complaint received by this Agency and the investigation carried out, the following is deduced:

The complainant was requested by MAPFRE to provide their last three payslips and a document certifying the indefinite nature of the employment contract, which documentation was provided.

However, after the delivery of this documentation, the respondent additionally requests the submission of a copy of the complainant's income tax return (IRPF) as well as their work history.

The respondent has provided a document titled “ISSUANCE, SUBSCRIPTION, AND RENTAL PROTECTION RATES RULES.” In this document, the documentation that must be provided by the guarantor in the event of a guarantee is listed: “Last payslip showing seniority and type of contract (if not expressly detailed, a certificate from the company must be attached to prove it, a copy of the employment contract, or work history) and last income tax return.”

In this regard, it should be noted that the complainant stated that they had provided, in addition to the last three payslips, a certificate that verified the indefinite nature of the employment contract. Since this document is required alternatively to the copy of the contract or the work history, once provided, it would not be necessary to submit either of the other two.

Therefore, this Agency, examining the reported facts, considers that requiring the work history for the formalization of the rental insurance contract, after a document certifying the indefinite nature of the employment contract has been provided, could constitute a violation of the principle of data minimization that requires that its processing be adequate, relevant, and limited to what is necessary in relation to the purposes for which it is processed.

IV

Classification of the infringement of Article 5.1.c) of the GDPR

If confirmed, the aforementioned infringement of Article 5.1.f) of the GDPR could imply the commission of the infringements classified in Article 83.5 of the GDPR, which under the heading “General

conditions for the imposition of administrative fines” states:

“Violations of the following provisions shall be subject to administrative fines of up to 20,000,000 EUR or, in the case of an enterprise, an amount equivalent to 4% of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9; (...)”

In this regard, the LOPDGDD, in its Article 71 “Infringements” establishes that “Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements.”

For the purposes of the limitation period, Article 72 “Very serious infringements” of the LOPDGDD indicates:

“1. In accordance with what is established in Article 83.5 of Regulation (EU) 2016/679, the following are considered very serious and shall be subject to a three-year limitation period: infringements that constitute a substantial violation of the articles mentioned therein and, in particular, the following:

a) The processing of personal data in violation of the principles and guarantees established in Article 5 of Regulation (EU) 2016/679. (...)”

V

Sanction for the infringement of Article 5.1.c) of the GDPR

For the purpose of deciding on the imposition of an administrative fine and its amount, in accordance with the evidence available at this time in the initiation agreement of the sanctioning procedure, and without prejudice to what results from the instruction, it is appropriate to grade the sanction to be imposed according to the following criteria established in Article 83.2 of the GDPR:

As aggravating factors:

- b) the intentionality or negligence in the infringement;

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

9/28

In this same sense, the Supreme Court has understood that there is negligence whenever a legal duty of care is disregarded, that is, when the offender does not behave with the required diligence. In assessing the degree of diligence, the professionalism or lack thereof of the subject must be especially weighed, and there is no doubt that, in the case now examined, when the activity of the appellant involves constant and abundant handling of personal data, it is necessary to insist on the rigor and exquisite care to comply with the legal provisions in this regard. [Judgment of the National Court of 10/17/2007 (rec. 63/2006)]

Furthermore, it is considered appropriate to grade the sanction to be imposed according to the following criteria established in section 2 of Article 76 “Sanctions and corrective measures” of the LOPDGDD:

As aggravating factors:

b) The connection of the offender's activity with the processing of personal data.

MAPFRE is a large company whose corporate purpose is, in relation to the facts judged, the carrying out of insurance and reinsurance operations in all branches and modalities of risk coverage. Part of its daily and continuous activity involves the large-scale processing of personal data for the normal development of its activities.

The balance of the circumstances contemplated in Article 83.2 of the GDPR and Article 76.2 of the LOPDGDD, regarding the infringement committed by violating what is established in Article 5.1.c) of the GDPR, allows for an initial sanction of €70,000 (SEVENTY THOUSAND EUROS).

VI

Infringement of Article 13 of the GDPR

Article 13 of the GDPR establishes the information that must be provided when personal data is obtained from the data subject, indicating the following:

“1. When personal data relating to a data subject is obtained from the data subject, the data controller

shall provide the data subject with all the information indicated below at the time the data is obtained:

- a) the identity and contact details of the controller and, where applicable, of its representative;
- b) the contact details of the data protection officer, where applicable;
- c) the purposes of the processing for which the personal data are intended and the legal basis for the processing;
- d) when the processing is based on Article 6(1)(f), the legitimate interests pursued by the controller or a third party;
- e) the recipients or categories of recipients of the personal data, where applicable;
- f) where applicable, the intention of the controller to transfer personal data to a third country or international organization and the existence or absence of an adequacy decision by the Commission, or, in the case of transfers referred to in Articles 46 or 47 or Article 49(1), second paragraph, reference to the appropriate safeguards and the means to obtain a copy of these or the fact that they have been provided.

2. In addition to the information mentioned in paragraph 1, the controller shall provide the data subject, at the time the personal data is obtained, with the following information necessary to ensure fair and transparent processing of data:

- a) the period for which the personal data will be stored or, when that is not possible, the criteria used to determine that period;
- b) the existence of the right to request from the controller access to personal data relating to the data subject, and their rectification or erasure, or the restriction of processing, or to object to the processing, as well as the right to data portability;
- c) when the processing is based on Article 6(1)(a) or Article 9(2)(a), the existence of the right to withdraw consent at any time, without affecting the lawfulness of the processing based on consent before its withdrawal;
- d) the right to lodge a complaint with a supervisory authority;
- e) whether the provision of personal data is a statutory or contractual requirement, or a requirement necessary to enter into a contract, and whether the data subject is obliged to provide the personal data and is informed of the possible consequences of failing to provide such data;
- f) the existence of automated decision-making, including profiling, referred to in Article 22(1) and (4), and, at least in such cases, meaningful information about the logic involved, as well as the significance and the envisaged consequences of such processing for the data subject.

3. When the controller intends to further process personal data for a purpose other than that for which it was collected, it shall provide the data subject, prior to that further processing, information about that other purpose and any further relevant information in accordance with paragraph 2.

4. The provisions of paragraphs 1, 2, and 3 shall not apply when and to the extent that the data subject already has the information.”

This Agency, examining the reported facts, considers that in this case the responding party requests the claimant (guarantor) for their personal data without providing the information required by data protection regulations when these are obtained from the data subject, alleging the responding party in 11/28

in its defense that such personal data is requested by the property owner and that they collect it on their behalf, which did not happen in this case under examination, as the data was requested directly by MAPFRE from the claimant.

Thus, the responding party seeks to shield itself with the fact that, according to the documentation attached to its allegations, it would be the policyholder (the landlord of the property) who would be obliged to provide the information related to the processing, as well as to collect the necessary documentation from the tenant or guarantor. However, the truth is that, according to the complaint received (and these facts are not denied by the responding party), in the case at hand, MAPFRE directly approached the guarantor to collect the documentation, thus failing to provide the information it is obliged to, as the data controller collecting the data, in accordance with Article 13 of the GDPR, which establishes the information obligations when personal data is obtained from the data subject. Therefore, since MAPFRE, in this specific case, directly requested the documentation from the claimant, the moment it should have informed the claimant was at the time of data collection and not at

the time of contracting the insurance, and by failing to do so, it violates Article 13 of the GDPR. In light of this, in accordance with the indications available at this moment in the initiation agreement of the sanctioning procedure, and without prejudice to what results from the instruction, the described facts, in this specific case, would constitute a violation of the provisions of Article 13 of the GDPR.

VII

Classification of the violation of Article 13 of the GDPR.

If confirmed, the aforementioned violation of Article 5.1.f) of the GDPR could imply the commission of the violations classified in Article 83.5 of the GDPR, which under the heading "General conditions for the imposition of administrative fines" states:

"Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 20,000,000 EUR or, in the case of an enterprise, an amount equivalent to 4% at most of the total annual global turnover of the previous financial year, opting for the higher amount:

b) the rights of data subjects under Articles 12 to 22; [...]"

For the purposes of the statute of limitations for violations, the violation indicated in the previous paragraph is considered very serious and is subject to a three-year limitation period, in accordance with Article 73 h) of the LOPDGDD, which establishes that:

"Minor violations of a merely formal nature of the articles mentioned in paragraphs 4 and 5 of Article 83 of Regulation (EU) 2016/679 shall be considered minor and shall expire after one year, and in particular, the following:

h) The omission of the duty to inform the affected party about the processing of their personal data in accordance with the provisions of Articles 13 and 14 of Regulation (EU) 2016/679 and 12 of this organic law."

VIII

Sanction for the violation of Article 13 of the GDPR

For the purposes of deciding on the imposition of an administrative fine and its amount, in accordance with the evidence available at this moment in the initiation agreement of the sanctioning procedure, and without prejudice to what results from the instruction, it is appropriate to grade the sanction to be imposed according to the following criteria established in Article 83.2 of the GDPR:

As aggravating factors:

b) the intentionality or negligence in the violation;

In this same sense, the Supreme Court has understood that there is negligence whenever a legal duty of care is neglected, that is, when the offender does not behave with the required diligence. And in assessing the degree of diligence, the professionalism or lack thereof of the subject must be especially weighed, and there is no doubt that, in the case now examined, when the activity of the appellant involves constant and abundant handling of personal data, it must be insisted upon the rigor and exquisite care to comply with the legal provisions in this regard. [Judgment of the National Court of 17/10/2007 (rec. 63/2006)]

It is also considered appropriate to grade the sanction to be imposed according to the following criteria established in paragraph 2 of Article 76 "Sanctions and corrective measures" of the LOPDGDD:

As an aggravating factor:

b) The link of the infringer's activity with the processing of personal data.

MAPFRE is a large company whose corporate purpose is, in relation to the facts under examination, the carrying out of insurance and reinsurance operations in all branches and modalities of risk coverage. Part of its daily and ongoing activity involves the large-scale processing of personal data for the normal development of its activities.

The balance of the circumstances contemplated in Article 83.2 of the GDPR and Article 76.2 of the LOPDGDD, with respect to the violation committed by breaching the provisions of Article 13 of the GDPR, allows for an initial sanction of €70,000 (SEVENTY THOUSAND EUROS).

IX

Violation of Article 25 of the GDPR

13/28

For its part, Article 25 of the GDPR, regarding Data Protection by Design and by Default, establishes

the following:

“1. Taking into account the state of the art, the cost of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying likelihood and severity that the processing poses to the rights and freedoms of natural persons, the data controller shall implement, both at the time of determining the means of processing and at the time of the processing itself, appropriate technical and organizational measures, such as pseudonymization, designed to effectively apply the principles of data protection, such as data minimization, and to integrate the necessary safeguards into the processing, in order to comply with the requirements of this Regulation and protect the rights of the data subjects.

2. The data controller shall implement appropriate technical and organizational measures to ensure that, by default, only personal data that are necessary for each specific purpose of the processing are processed. This obligation shall apply to the amount of personal data collected, the extent of their processing, the duration of their storage, and their accessibility. Such measures shall ensure, in particular, that, by default, personal data are not accessible, without the intervention of the data subject, to an indeterminate number of natural persons.

3. An approved certification mechanism under Article 42 may be used as an element to demonstrate compliance with the obligations set out in paragraphs 1 and 2 of this Article.”

In line with these provisions, Recital 78 of the GDPR states:

“The protection of the rights and freedoms of natural persons with regard to the processing of personal data requires the adoption of appropriate technical and organizational measures to ensure compliance with the requirements of this Regulation.

In order to demonstrate compliance with this Regulation, the data controller must adopt internal policies and implement measures that particularly comply with the principles of data protection by design and by default.

Such measures could consist, among others, of minimizing the processing of personal data, pseudonymizing personal data as soon as possible, providing transparency regarding the functions and processing of personal data, allowing data subjects to monitor the processing of data, and enabling the data controller to create and improve security elements.

When developing, designing, selecting, and using applications, services, and products that are based on the processing of personal data or that process personal data to fulfill their function, producers of products, services, and applications should be encouraged to take into account the right to data protection when developing and designing these products, services, and applications, and to ensure, with due regard to the state of the art, that data controllers and processors are in a position to fulfill their obligations regarding data protection.

The principles of data protection by design and by default should also be considered in the context of public contracts.”

On the other hand, it should be noted that Article 14 of the GDPR, relating to the information that must be provided when personal data have not been obtained from the data subject, establishes the following:

“1. When personal data have not been obtained from the data subject, the data controller shall provide the following information:

- a) the identity and contact details of the controller and, where applicable, of its representative;
- b) the contact details of the data protection officer, where applicable;
- c) the purposes of the processing for which the personal data are intended, as well as the legal basis for the processing;
- d) the categories of personal data concerned;
- e) the recipients or categories of recipients of the personal data, if any;
- f) where applicable, the intention of the controller to transfer personal data to a recipient in a third country or an international organization and the existence or absence of an adequacy decision by the Commission, or, in the case of transfers referred to in Articles 46 or 47 or Article 49, paragraph 1, second subparagraph, reference to the appropriate safeguards and the means to obtain a copy thereof or the fact that they have been provided.

2. In addition to the information mentioned in paragraph 1, the data controller shall provide the data

subject with the following information necessary to ensure fair and transparent processing of data concerning the data subject:

- a) the period for which the personal data will be stored or, when that is not possible, the criteria used to determine that period;
- b) where the processing is based on Article 6, paragraph 1, letter f), the legitimate interests of the data controller or a third party;
- c) the existence of the right to request from the data controller access to personal data concerning the data subject, and their rectification or erasure, or the restriction of processing, and to object to the processing, as well as the right to data portability;
- d) where the processing is based on Article 6, paragraph 1, letter a), or Article 9, paragraph 2, letter a), the existence of the right to withdraw consent."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

15/28

at any time, without affecting the lawfulness of the processing based on consent before its withdrawal;

- e) the right to lodge a complaint with a supervisory authority;
- f) the source from which the personal data originates and, where applicable, whether it comes from publicly accessible sources;
- g) the existence of automated decision-making, including profiling, referred to in Article 22, paragraphs 1 and 4, and, at least in such cases, meaningful information about the logic involved, as well as the significance and the expected consequences of such processing for the data subject.

3. The data controller shall provide the information indicated in paragraphs 1 and 2:

- a) within a reasonable timeframe, once the personal data has been obtained, and no later than within one month, taking into account the specific circumstances in which the data is processed;
- b) if the personal data is to be used for communication with the data subject, no later than at the time of the first communication to that data subject, or
- c) if it is intended to communicate it to another recipient, no later than at the time when the personal data is communicated for the first time.

4. When the data controller intends to process the personal data for a purpose other than that for which it was obtained, it shall provide the data subject, prior to such further processing, information about that other purpose and any other relevant information indicated in paragraph 2.

In this case, it should be noted that MAPFRE is the data controller, as it establishes the means and purposes for the processing of personal data involved in the conclusion and execution of insurance contracts, and therefore must ensure the information to all data subjects participating in the contract. In the rental guarantee insurance contract in question, the obligations of obtaining documentation and information regarding the protection of personal data are transferred to the policyholder. This is stated in various documents:

- In the document "APPLICATION AND QUESTIONNAIRE FOR RENTAL PROTECTION INSURANCE," the clause states, "The applicant, in their capacity as the landlord of the described property, declares that they have received and hold one of the following documents provided by the tenant(s) or guarantor(s) in the case of personal guarantee, for the purpose of justifying the tenant(s)' payment capacity for the insurance contract and that the tenant's employment situation is as indicated (mark with X the corresponding boxes):"

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

16/28

- In the same document, regarding information to third parties involved, such as the guarantor, it states the following: "In the event that the data provided refers to third parties other than the

Policyholder/Insured/Affected, they guarantee that they have obtained and have the prior consent of the same for the communication of their data and have informed them, prior to their inclusion in this document, of the purposes of the processing, communications, and other terms provided herein and in the Additional Data Protection Information."

This transfer of responsibility to inform third parties such as the guarantor about the protection of their personal data is corroborated by the Data Protection Officer of the responding party, who, in their report submitted along with the allegations of the responding party and which is undated, states the following in the section "Duty of Information":

(...).

Thus, both from the documentation provided and from the report of the Data Protection Officer of MAPFRE, it is clearly deduced that, even though the obligation to provide information about data protection lies with the data controller (in this case, MAPFRE), when personal data is provided by third parties, such as the landlord and policyholder, different from the data subject, the obligation to provide information (which would fall under Article 14 of the GDPR since the data was not obtained from the data subject) is not exercised by the data controller itself, but is contractually transferred to the policyholder.

Apart from the above, as can be easily observed in the allegations of the responding party, there is a transfer of the responsibility to provide information without any mechanism or procedure established by MAPFRE to ensure that the policyholder provides adequate information to third parties. Furthermore, it should be noted that in this case, the information was not provided by the policyholder to the complaining party and MAPFRE, not having a procedure designed to ensure the provision of information, did nothing in this regard until it received the complaint from the complaining party.

Under the guise of a merely formal attribution of the responsibility to inform (which MAPFRE assigns to the policyholder), in essence, the responding party neglects the information obligations imposed on it by Article 14 of the GDPR. There are no precautions or control mechanisms that ensure that the responding party guarantees that the information is actually provided. In this regard, it must be emphasized that the GDPR imposes this obligation on the data controller, in this case, MAPFRE.

The principle of privacy by design is a demonstration of the shift from reactivity to

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

17/28

the proactivity and direct manifestation of the risk-based approach imposed by the GDPR. Part of the proactive responsibility requires that, from the earliest stages of planning a processing operation, this principle must be considered: the data controller, from the moment an eventual processing of personal data is designed and planned, must determine all the elements that make up the processing, in order to effectively apply the principles of data protection, integrating the necessary safeguards into the processing with the ultimate aim of, in compliance with the provisions of the GDPR, protecting the rights of the data subjects. Thus, regarding the risks that may be present in the processing, the data controller will carry out an exercise of analysis and detection of risks throughout the entire data processing cycle, with the primary and ultimate aim of protecting the rights and freedoms of the data subjects, and not only when the processing actually takes place. This is expressed in the Guidelines 4/2019 of the EDPB regarding Article 25 Data Protection by Design and by Default, adopted on October 20, 2020.

In the aforementioned Guidelines, it is indicated that:

"35. The 'moment of determining the means of processing' refers to the period of time in which the controller is deciding how the processing will be carried out and how it will occur, as well as the mechanisms that will be used to carry out such processing. In the process of making such decisions, the data controller must evaluate the appropriate measures and safeguards to effectively apply the principles and rights of the data subjects in the processing, and take into account elements such as risks, the state of the art, and the cost of implementation, as well as the nature, scope, context, and purposes. This includes the moment of acquiring and implementing the software and hardware and the

data processing services.

36. Taking into account Data Protection by Design and by Default from the outset is crucial for the correct application of the principles and for the protection of the rights of the data subjects.

Furthermore, from a cost-effectiveness perspective, it is also in the interest of data controllers to consider Data Protection by Design and by Default as early as possible, as it may later become difficult and costly to introduce changes into already formulated plans and designed processing operations.”

To this end, the data controller must refer to the principles set out in Article 5 of the GDPR when designing the processing, which will serve to assess the effective compliance with the GDPR. Thus, the aforementioned Guidelines 4/2019 of the EDPB state that “61. To make Data Protection by Design and by Default effective, data controllers must apply the principles of transparency, lawfulness, fairness, purpose limitation, data minimization, accuracy, storage limitation, integrity and confidentiality, and proactive responsibility. These principles are set out in Article 5 and Recital 39 of the GDPR.”

The Privacy by Design Guide of the AEPD states that “Privacy by Design (hereinafter, PbD) involves using a risk management and proactive responsibility-oriented approach to establish strategies that incorporate privacy protection throughout the entire lifecycle of the object (whether it is a system, a hardware or software product, a service, or a process). By lifecycle of the...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

18/28

The term "object" refers to all the stages that it goes through, from its conception to its withdrawal, including the phases of development, production, operation, maintenance, and withdrawal.

The Guide states that “Privacy must be an integral and indissoluble part of the systems, applications, products, and services, as well as the business practices and processes of the organization. It is not an additional layer or module that is added to something pre-existing, but must be integrated into the set of non-functional requirements from the moment it is conceived and designed (...) Privacy is born in the design, before the system is operational, and must be guaranteed throughout the entire data lifecycle.”

Therefore, privacy by design, an obligation of the data controller that arises before the system is operational, is not merely an addition that is layered onto a system built in disregard of the GDPR.

Linked to the establishment of a true culture of data protection within the organization, it also implies, due to proactive responsibility, the ability to document all decisions made with a “privacy design thinking” approach, demonstrating compliance with the GDPR in this aspect as well.

The risk-based approach refers directly and immediately to a preventive system aimed at visualizing, regarding the processing of personal data, the risks to the rights and freedoms of individuals. In relation to the risks to those rights and freedoms, risks must be identified, their impact assessed, and the probability of their materialization evaluated. Thus, it is not the data that is protected, but the individuals behind it.

The risks to the rights and freedoms of individuals, arising from the processing of personal data, can vary in severity and probability and can cause physical, material, or immaterial harm, tangible or intangible consequences, to the rights and freedoms of individuals. Recital 75 of the GDPR and Article 28.2 of the LOPDGDD exemplify some of the risks considered by the legislator, but they are not the only ones. It will depend on the processing and the context in which it is carried out, the personal data processed, the individuals involved, the means used, etc.

In this regard, the responding party has provided, in relation to the right to information referred to in this file, certain documentation that merely shifts the responsibility of informing third parties involved to any holder of the rental guarantee insurance. And we have already mentioned that the principle of privacy by design is a demonstration of the shift from reactivity to proactivity and is a reflection of the risk-based approach imposed by the GDPR.

With the documentation provided by MAPFRE, there is merely a formal displacement of the obligation, but the rights and freedoms of the participants are not protected, which is the ultimate goal pursued by

the GDPR through data protection by design. Therefore, MAPFRE does not have a procedure for complying with the principle of proactive responsibility (Article 5.2 GDPR), as it should have started from the aforementioned risk analysis that would lead to the adoption of technical and organizational measures of all kinds for the protection of the data.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
19/28

Rights and freedoms, always starting from the design of the processing. There is no mechanism established by the responding party that guarantees that a possible breach by the data controller of the obligation to inform will be remedied by the responsible party. Thus, none of these aspects are controlled or guaranteed:

- Whether or not the data subject has been informed
- The content of such information
- The accuracy of the information transmitted

From this perspective, the already mentioned Privacy by Design Guide from the AEPD establishes various guidelines that are not fulfilled in the case at hand:

“Any system, process, or infrastructure that will use personal data must be conceived and designed from scratch, identifying, a priori, the possible risks to the rights and freedoms of the data subjects and minimizing them so that they do not materialize into harm. A PbD policy is characterized by the adoption of proactive measures that anticipate threats, identifying the weaknesses of the systems to neutralize or minimize risks instead of applying corrective measures to resolve security incidents once they have occurred. That is to say, PbD avoids the ‘remediation policy’ and anticipates the materialization of the risk event.”

Privacy as the default setting:

“PbD aims to provide the user with the maximum level of privacy given the state of the art and, in particular, that personal data is automatically protected in any system, application, product, or service. The default setting must be established from the design at a level that is as respectful as possible in terms of privacy. In the event that the subject does not take any configuration action, their privacy must be guaranteed and remain intact, as it is integrated into the system and configured by default.”

Privacy embedded in the design phase:

“Privacy must be an integral and inseparable part of the systems, applications, products, and services, as well as the business practices and processes of the organization. It is not an additional layer or module that is added to something pre-existing, but must be integrated into the set of non-functional requirements from the very moment it is conceived and designed. To ensure that privacy is taken into account from the early stages of design, it must:

- Be considered a necessary requirement in the lifecycle of systems and services, as well as in the design of the organization’s processes.
- Conduct a risk analysis for the rights and freedoms of individuals and, where applicable, impact assessments related to data protection, as an integral part of the design of any new processing initiative.
- Document all decisions made within the organization with a “privacy design thinking” approach.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
20/28

Thus, the contracting procedures for financial products of the responding party require, in terms of data protection, a proper analysis of the risks to the rights and freedoms of the clients, adequate planning, the establishment of security measures to prevent risks, maintenance, updating, and control of those

measures through continuous risk review, including the demonstration of compliance (observance of the principle of proactive responsibility), especially, in the case at hand, in relation to the right to information. This is to ensure the Fundamental Right to Data Protection of the clients, which includes the effective availability of personal data by the data subjects, as well as ensuring the information of the data subjects whose data is being processed. Compliance with this obligation imposed by the GDPR on the data controller is achieved through privacy by design.

From the documentation provided by MAPFRE in the investigation of this procedure, the non-compliance with the obligation imposed by Article 25 of the GDPR is evident, and the measures adopted by this entity cannot be considered as fulfilling the provisions of that article, which urges the protection of the rights and freedoms of citizens in the processing of their data, not merely the formal imposition of obligations on other parties.

The documents provided do not contain any analysis of this risk and, consequently, did not establish technical or organizational measures that could prevent the infringement of the fundamental right to data protection, and along with it, the rights and information assets held by the clients of the banking entity.

In this regard, it should be noted that according to Article 25 of the GDPR:

“Taking into account the state of the art, the cost of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying likelihood and severity that the processing may pose to the rights and freedoms of natural persons, the data controller shall implement, both at the time of determining the means of processing and at the time of the processing itself, appropriate technical and organizational measures, such as pseudonymization, designed to effectively apply the principles of data protection, such as data minimization, and to integrate the necessary safeguards into the processing, in order to meet the requirements of this Regulation and protect the rights of data subjects.”

That is to say, the protection of the fundamental right to data protection does not consist of a mere “reactive” waiting for a problem that may infringe it to occur, but rather that the data controllers must design (“data protection by design”) appropriate policies for the protection of this fundamental right prior to the commencement of processing. This includes all aspects regulated in the GDPR, starting with the obligations of transparency, respect for the exercise of the rights established in the Regulation, and the establishment of all necessary technical and organizational measures to ensure compliance with this regulation. All of this must be planned and implemented prior to the commencement of processing by the controller.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

21/28

As a result of the inspection actions carried out by this Agency, as well as the rest of the documentation and allegations presented by MAPFRE in this procedure, it has been confirmed that the aforementioned principle (and consequently Article 25 of the GDPR) was not complied with by the party being claimed against. There was no procedure in place to mitigate the risks of lack of information to third parties involved in the contracting processes.

In this regard, risk analysis is a key component of the principle of privacy by design, as it allows for the establishment of technical and organizational measures that prevent or, in the event of occurrence, mitigate those risks. As noted, Article 25 specifically refers to “the risks of varying probability and severity that the processing entails for the rights and freedoms of natural persons,” as a prerequisite for the establishment of such measures.

It has been verified that neither the risk was established nor the measures implemented. All of this is corroborated through the documentation of the procedure provided by the party being claimed against. In light of these circumstances, this Agency considers that the entity being claimed against may have violated Article 25 of the GDPR in relation to Article 14 of the GDPR, which regulates data protection by design and by default, where the data controller is required to apply, both at the time of determining the means of processing and at the time of the processing itself, appropriate technical and

organizational measures designed to effectively implement the principles of data protection and integrate the necessary safeguards into the processing, in order to comply with the requirements of the GDPR and protect the rights of the data subjects.

Without prejudice to the outcome of the investigation, the described facts would constitute a violation of the provisions of Article 25 of the GDPR.

X

Classification of the violation of Article 25 GDPR

The violation of Article 25 of the GDPR is classified under Article 83.4 of the same legal text, which states:

“Violations of the following provisions shall be subject to administrative fines of up to 10,000,000 EUR or, in the case of an enterprise, an amount equivalent to up to 2% of the total annual global turnover of the preceding financial year, opting for the higher amount:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43;”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

22/28

For the purposes of the statute of limitations for violations, the violation indicated in the previous paragraph is considered serious and is subject to a two-year limitation period, in accordance with Article 73 d) of the LOPDGDD, which establishes that:

“According to what is established in Article 83.4 of Regulation (EU) 2016/679, the following violations are considered serious and shall be subject to a two-year limitation period:

d) The failure to adopt those technical and organizational measures that are appropriate to effectively apply the principles of data protection by design, as well as the failure to integrate the necessary safeguards into the processing, as required by Article 25 of Regulation (EU) 2016/679.”

XI

Sanction for the violation of Article 25 GDPR

For the purpose of deciding on the imposition of an administrative fine and its amount, in accordance with the evidence available at this moment of the initiation of the sanctioning procedure, and without prejudice to the outcome of the investigation, it is appropriate to gradate the sanction to be imposed according to the following criteria established in Article 83.2 of the GDPR:

As aggravating factors:

a) the nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question as well as the number of affected data subjects and the level of damage and harm they have suffered;

In this regard, it is worth highlighting two concurrent aspects: on one hand, the number of affected individuals, since the infringement, referring to the established procedure to guarantee the right to information, affects all natural persons involved in the conclusion of rental guarantee insurance contracts.

Moreover, the affected individuals suffer harm due to the infringement, as their right to receive information about the processing of their personal data has been violated, covering such important aspects as the determination of the data controller, the retention period of the data, or their right to lodge a complaint.

b) the intentionality or negligence in the infringement;

In this same sense, the Supreme Court has understood that there is negligence whenever a legal duty of care is disregarded, that is, when the infringer does not act with the required diligence. In assessing the degree of diligence, the professionalism or lack thereof of the subject must be particularly weighed, and there is no doubt that, in the case currently examined, when the activity of the appellant is constant and...

C/ Jorge Juan, 6

www.aepd.es

The abundant handling of personal data must emphasize the rigor and exquisite care to comply with the legal provisions in this regard. [Judgment of the National Court of October 17, 2007 (rec. 63/2006)] It is also considered appropriate to adjust the sanction to be imposed according to the following criteria established in section 2 of Article 76 “Sanctions and corrective measures” of the LOPDGDD:

As an aggravating factor:

b) The link between the infringer's activity and the processing of personal data.

MAPFRE is a large company whose corporate purpose is, in relation to the facts under judgment, the performance of insurance and reinsurance operations in all branches and modalities of risk coverage. Part of its daily and continuous activity involves the large-scale processing of personal data for the normal development of its activities.

The balance of the circumstances contemplated in Article 83.2 of the GDPR and Article 76.2 of the LOPDGDD, regarding the infringement committed by violating the provisions established in Article 25 of the GDPR, allows for an initial sanction of €1,000,000 (ONE MILLION EUROS).

XII

Imposition of measure

If the infringement is confirmed, it could be agreed to impose on the responsible party the adoption of appropriate measures to adjust its actions to the regulations mentioned in this act, in accordance with the provisions of the aforementioned Article 58.2 d) of the GDPR, according to which each supervisory authority may “order the controller or processor to ensure that the processing operations comply with the provisions of this Regulation, where appropriate, in a specific manner and within a specified time frame...”.

The imposition of this measure is compatible with the sanction consisting of an administrative fine, as provided for in Article 83.2 of the GDPR.

In such a case, in the resolution adopted, this Agency may require the responsible entity to, within the determined period, adapt the processing operations it carries out to the personal data protection regulations, with the scope expressed in the Legal Grounds of this agreement and without prejudice to what results from the instruction.

In particular, it may be ordered that the responsible party establish a procedure that ensures that when personal data is not collected directly by the responsible party, the provision of information is guaranteed from the principle of privacy by design and with the elements that this implies, in order to provide the information in the terms of Article 14.

It is noted that failure to comply with the possible order to adopt measures imposed by this agency in the sanctioning resolution may be considered an administrative infringement in accordance with the provisions of the GDPR, classified as an infringement in its Articles 83.5 and 83.6, which may lead to the initiation of further administrative sanctioning proceedings.

Therefore, in accordance with the applicable legislation and having assessed the criteria for the graduation of sanctions,

By the Director of the Spanish Agency for Data Protection, IT IS AGREED:

FIRST: TO INITIATE SANCTIONING PROCEDURE against MAPFRE ESPAÑA COMPAÑÍA DE SEGUROS Y REASEGUROS, S.A. with NIF A28141935, for the alleged infringements of Articles 5.1c), 13, and 25 of the GDPR, classified in Articles 83.5 and 83.4 of the aforementioned regulation.

SECOND: TO APPOINT C.C.C. as the instructor and D.D.D. as the secretary, indicating that they may be challenged, if applicable, in accordance with the provisions of Articles 23 and 24 of Law 40/2015, of October 1, on the Legal Regime of the Public Sector (LRJSP).

THIRD: TO INCORPORATE into the sanctioning file, for evidentiary purposes, the complaint filed by the complainant and its documentation, as well as the documents obtained and generated by the General Subdirectorate of Data Inspection in the proceedings prior to the initiation of this sanctioning procedure.

FOURTH: THAT for the purposes provided in Article 64.2 b) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, and without prejudice to what results

from the instruction, the sanctions that may correspond would be:

- For the alleged infringement of Article 5.1 c) of the GDPR for being excessive to require the work history for the conclusion of the rental insurance contract, if a certificate regarding the employment contract has already been provided: SEVENTY THOUSAND EUROS (€70,000).
- For the alleged infringement of Article 13 of the GDPR, since the entity being claimed, when formalizing not only the contract in question but generally when entering into a rental insurance contract, does not have any mechanism to ensure that the third party is informed about the processing of their data: SEVENTY THOUSAND EUROS (€70,000).
- For the alleged infringement of Article 25 of the GDPR, for not informing the complainant about the processing of their personal data at the time of collection: ONE MILLION EUROS (€1,000,000).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

25/28

This amounts to ONE MILLION ONE HUNDRED FORTY THOUSAND EUROS (1,140,000€)

FIFTH: NOTIFY this agreement to MAPFRE ESPAÑA COMPAÑÍA DE SEGUROS Y REASEGUROS, S.A. with NIF A28141935, granting a hearing period of ten working days for them to formulate allegations and present any evidence they deem appropriate. In their written allegations, they must provide their NIF and the procedure number that appears in the heading of this document.

If they do not make allegations against this initial agreement within the stipulated period, it may be considered a proposal for resolution, as established in Article 64.2.f) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP).

In accordance with the provisions of Article 85 of the LPACAP, they may acknowledge their responsibility within the period granted for formulating allegations to this initial agreement; this will entail a 20% reduction of the sanction that may be imposed in this procedure. With the application of this reduction, the sanction would be set at 912,000 euros, resolving the procedure with the imposition of this sanction.

Similarly, they may, at any time prior to the resolution of this procedure, make voluntary payment of the proposed sanction, which will imply a 20% reduction of its amount. With the application of this reduction, the sanction would be set at 912,000 euros, and its payment will imply the termination of the procedure, without prejudice to the imposition of the corresponding measures.

The reduction for the voluntary payment of the sanction is cumulative with the one corresponding to the acknowledgment of responsibility, provided that this acknowledgment of responsibility is made within the period granted for formulating allegations to the opening of the procedure. The voluntary payment of the amount referred to in the previous paragraph may be made at any time prior to the resolution. In this case, if both reductions are applicable, the amount of the sanction would be set at 684,000 euros.

In any case, the effectiveness of either of the two mentioned reductions will be conditioned upon the withdrawal or waiver of any action or administrative appeal against the sanction.

In the event that they choose to proceed with the voluntary payment of any of the amounts indicated above (912,000 euros or 684,000 euros), they must make it effective by depositing it into account No. IBAN: ES00 0000 0000 0000 0000 0000 opened in the name of the Spanish Agency for Data Protection at the banking entity CAIXABANK, S.A., indicating in the concept the reference number of the procedure that appears in the heading of this document and the reason for the reduction of the amount to which they are entitled.

Furthermore, they must send the proof of deposit to the General Sub-Directorate of Inspection to continue with the procedure in accordance with the amount deposited.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

26/28

The procedure will have a maximum duration of twelve months from the date of the initial agreement or, where applicable, from the draft initial agreement. After this period, it will expire, and consequently, the file will be archived; in accordance with the provisions of Article 64 of the LOPDGDD.

Finally, it is noted that according to the provisions of Article 112.1 of the LPACAP, there is no administrative appeal against this act.

935-170223

Mar España Martí

Director of the Spanish Agency for Data Protection

>>

SECOND: On October 26, 2023, the respondent has proceeded to pay the sanction in the amount of 684,000 euros, making use of the two reductions provided for in the previously transcribed Initial Agreement, which implies the acknowledgment of responsibility.

THIRD: The payment made, within the period granted for formulating allegations to the opening of the procedure, entails the waiver of any action or administrative appeal against the sanction and the acknowledgment of responsibility concerning the facts referred to in the Initial Agreement.

FOURTH: The Initial Agreement transcribed above indicated that, if the infringement were confirmed, it could be agreed to impose on the responsible party the adoption of appropriate measures to adjust their actions to the regulations mentioned in this act, in accordance with the provisions of the aforementioned Article 58.2 d) of the GDPR, according to which each supervisory authority may "order the controller or processor to ensure that the processing operations comply with the provisions of this Regulation, where appropriate, in a specified manner and within a specified time frame...".

Having acknowledged the responsibility for the infringement, the imposition of the measures included in the Initial Agreement is appropriate.

LEGAL GROUNDS

I

Competence

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of the

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

27/28

Organic Law 3/2018, of December 5, on the Protection of Personal Data and Guarantee of Digital Rights (hereinafter, LOPDGDD), grants competence to initiate and resolve this procedure to the Director of the Spanish Agency for the Protection of Data.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Agency for the Protection of Data shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development, and, to the extent that they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Termination of the Procedure

Article 85 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), under the heading "Termination in Sanctioning Procedures" provides as follows:

"1. Once a sanctioning procedure has been initiated, if the offender acknowledges their responsibility, the procedure may be resolved with the imposition of the appropriate sanction.

2. When the sanction is solely of a pecuniary nature or when it is possible to impose a pecuniary sanction and another of a non-pecuniary nature but the imposition of the latter has been justified as inappropriate, voluntary payment by the presumed responsible party, at any time prior to the

resolution, will imply the termination of the procedure, except regarding the restoration of the altered situation or the determination of compensation for damages caused by the commission of the infringement.

3. In both cases, when the sanction is solely of a pecuniary nature, the competent authority to resolve the procedure shall apply reductions of at least 20% on the amount of the proposed sanction, which shall be cumulative. The aforementioned reductions must be specified in the notification of initiation of the procedure, and their effectiveness shall be conditioned upon the withdrawal or renunciation of any action or administrative appeal against the sanction. The percentage of reduction provided for in this section may be increased by regulation.”

In accordance with the above,

the Director of the Spanish Agency for the Protection of Data RESOLVES:

FIRST: TO DECLARE the termination of procedure EXP202209203, in accordance with the provisions of Article 85 of the LPACAP.

SECOND: TO ORDER MAPFRE ESPAÑA COMPAÑÍA DE SEGUROS Y REASEGUROS, S.A. to notify the Agency within 9 months of the adoption of the measures described in the legal grounds of the Agreement of initiation transcribed in this resolution.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

28/28

THIRD: TO NOTIFY this resolution to MAPFRE ESPAÑA COMPAÑÍA DE SEGUROS Y REASEGUROS, S.A.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure as provided by Article 114.1.c) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, the interested parties may file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and Section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law.

1259-121222

Mar España Martí

Director of the Spanish Agency for the Protection of Data

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es